

SafeLock

Coffre-Fort Numerique Personnel

PLAN DE CONTINUITE D'ACTIVITE et

PLAN DE REPRISE D'ACTIVITE

(PCA / PRA)

Version	1.2
Date	Juin 2026
Auteur	Raphael (GRC Lead)
Statut	Version intermédiaire
Document lie	PSSI SafeLock v1.1

1. Introduction, Contexte et Objectifs

1.1 Preamble

Ce document definit le Plan de Continuite d'Activite (PCA) et le Plan de Reprise d'Activite (PRA) pour le service SafeLock — Coffre-Fort Numerique Personnel. Il s'inscrit en complement de la Politique de Securite des Systemes d'Information (PSSI) et vise a garantir la resilience du service face a tout type d'incident majeur ou de sinistre.

L'objectif est de decire l'organisation, les procedures et les moyens techniques permettant de maintenir les activites critiques en mode degrade (continuite) et de restaurer l'ensemble des services dans des delais maitrises (reprise) en cas d'interruption.

1.2 Difference entre PCA et PRA

	PCA — Plan de Continuite d'Activite	PRA — Plan de Reprise d'Activite
Objectif	Maintenir une activite minimale PENDANT l'incident	Restaurer le service NORMAL APRES l'incident
Declenchement	Des la detection de l'incident	Une fois l'incident maitrise/resolu
Mode	Fonctionnement en mode degrade acceptable	Retour a la normale complete
Metrique cle	MAD (Maximum Allowable Downtime)	RTO (Recovery Time Objective)
Donnees cle	RPO (Recovery Point Objective)	RPO + integrite verifiee

1.3 Perimetre

Ce document couvre l'integralite du systeme SafeLock :

- Application web (frontend Next.js et backend API Routes)
- Infrastructure Docker (conteneurs applicatif, MySQL, MinIO)
- Base de donnees MySQL 8 (metadonnees, utilisateurs, audit)
- Stockage objets MinIO (blobs chiffres)
- Configuration et secrets associes
- Pipeline CI/CD (GitHub Actions)

2. Identification des Activites Critiques et Dependances

2.1 Cartographie des Services

Service / Composant	Criticite	Technologie	Role
Application Web (frontend)	HAUTE	Next.js 16 / React	Interface utilisateur, cryptographie client, acces aux fonctionnalites
API Backend	HAUTE	Next.js API Routes	Authentification, gestion des sessions, routage des requetes
Base de donnees MySQL	CRITIQUE	MySQL 8 Docker	Metadonnees utilisateurs, fichiers, cles chiffrees, sessions, audit
Stockage MinIO	CRITIQUE	MinIO (S3-compat.)	Stockage de l'ensemble des blobs chiffres des utilisateurs
Infrastructure Docker	HAUTE	Docker Compose	Orchestration et isolation des services
Base NoSQL (logs)	MOYENNE	A definir (ex: MongoDB)	Centralisation des evenements d'audit et de securite
CI/CD (GitHub Actions)	BASSE	GitHub	Pipeline de deploiement automatise — non critique en production

2.2 Dependances et Flux

- L'application web depend de l'API backend pour toutes les operations authentifiees
- L'API backend depend de MySQL pour l'authentification, les metadonnees et les sessions
- L'API backend depend de MinIO pour le stockage et la recuperation des fichiers
- La cryptographie client ne depend d'aucun service serveur (zero-knowledge)
- La perte de MySQL entraine l'indisponibilite totale du service (authentification impossible)
- La perte de MinIO entraine la perte d'accès aux fichiers uniquement (authentification et interface disponibles)

3. Objectifs de Continuite et de Reprise (RTO / RPO)

3.1 Definitions

- RTO (Recovery Time Objective) : duree maximale acceptable d'interruption du service — delai dans lequel le service doit etre restaure
- RPO (Recovery Point Objective) : perte de donnees maximale acceptable — age maximal de la derniere sauvegarde exploitable
- MAD (Maximum Allowable Downtime) : duree totale maximale d'indisponibilite avant impact critique irreversible

3.2 Objectifs par Composant

Composant	RTO	RPO	Justification
Application Web + API	< 2 heures	0 (stateless)	Service central — l'app est stateless, reprise rapide via Docker
MySQL (metadonnees)	< 4 heures	< 24 heures	Donnees critiques — sauvegarde quotidienne, restauration depuis dump
MinIO (fichiers chiffres)	< 6 heures	< 24 heures	Donnees importantes — replication ou restauration depuis snapshot
Service complet	< 8 heures	< 24 heures	Objectif global — ensemble de l'infrastructure reconstructible

Note : Ces objectifs sont definis pour un contexte academique. En production reelle, les RTO seraient generalement inferieurs (objectif RTO < 1h pour un service commercial equivalent).

4. Scenarios d'Interruption et Niveaux de Declenchement

4.1 Scenarios Identifies

Scenario	Probabilite	Severite	Impact principal
Panne materielle du serveur (HW)	Moyenne	Elevee	Indisponibilite totale — necessite reinstallation complete
Corruption de la base MySQL	Faible	Critique	Perte de metadonnees utilisateurs, cles chiffrees, sessions
Perte du stockage MinIO	Faible	Critique	Perte irrecuperable des fichiers utilisateurs si pas de backup
Incident de securite (intrusion)	Moyenne	Critique	Compromission potentielle, necessite isolation et forensique
Ransomware / malware	Faible	Critique	Chiffrement des donnees, necessite restauration depuis backup propre
Attaque DDoS	Moyenne	Moyenne	Indisponibilite temporaire sans perte de donnees
Erreur humaine (suppression accidentelle)	Elevee	Variable	Perte de donnees ou de configuration, recuperation depuis backup
Panne Docker / OS	Moyenne	Moyenne	Redemarrage rapide des services, donnees persistees sur volumes
Expiration de certificat HTTPS	Elevee	Faible	Avertissements navigateur, perte de confiance utilisateur
Fuite de secrets (.env)	Faible	Critique	Necessite rotation immediate de tous les secrets

4.2 Niveaux de Declenchement

Niveau	Etat du service	Declenchement	Plan active
VERT	Service nominal	Aucun incident	Monitoring standard — pas de PCA/ PRA
ORANGE	Service degrade	1 composant indisponible, service partiel	PCA — Mode degrade, investigation en cours
ROUGE	Service interrompu	Service totalement indisponible ou donnees compromises	PCA + PRA — Restauration complete

5. Plan de Continuite d'Activite (PCA)

5.1 Modes Degrades Acceptables

En cas d'incident partiel, les modes degrades suivants sont acceptables pendant la duree de l'investigation :

Composant en panne	Mode degrade	Limitation utilisateur
MinIO uniquement	Acces a l'interface maintenu, operations sur fichiers suspendues	L'utilisateur peut se connecter mais ne peut ni uploader ni downloader de fichiers
Base NoSQL (logs)	Service complet maintenu, journalisation degradee	Audit temps reel suspendu — journalisation minimale dans MySQL
1 instance applicative	Redirection du trafic sur instance saine	Possible augmentation de latence uniquement
CI/CD (GitHub Actions)	Deploiements manuels uniquement	Pas d'impact utilisateur final

5.2 Procedure de Basculement en Mode Degrade

En cas de passage en niveau **ORANGE** :

- 1. Detection de l'anomalie via les logs, alertes ou signalement utilisateur
- 2. Qualification : identification du composant defaillant (docker ps, healthchecks, logs applicatifs)
- 3. Communication interne immediate (Gaspard, Antoine, Raphael) via le canal de communication de crise
- 4. Decision de basculement : isoler le composant defaillant sans impacter les autres services
- 5. Mise en place du mode degrade : desactiver les fonctionnalites impactees via flags de configuration
- 6. Communication utilisateur : affichage d'un bandeau de maintenance dans l'interface
- 7. Suivi de la progression de l'investigation toutes les 30 minutes

5.3 Communication de Crise

- Canal principal : Teams — canal #incident-prod
- Escalade si non-reponse sous 15 minutes : appel telephone direct
- Responsable communication utilisateurs : Raphael (GRC Lead)
- Page de statut : a mettre en place (statut.safelock.local ou equivalent)
- Notification utilisateurs : email automatique si indisponibilite > 30 minutes

6. Plan de Reprise d'Activite (PRA)

6.1 Conditions de Declenchement du PRA

Le PRA est declenche dans les situations suivantes :

- Indisponibilite totale du service confirmee (niveau ROUGE)
- Corruption confirmee de donnees (base MySQL ou fichiers MinIO)
- Incident de securite avec necessite de reconstruction depuis un etat sain
- Ransomware ou malware confirme sur l'infrastructure
- Le PCA n'a pas permis de maintenir un service acceptable dans les delais MAD

6.2 Conditions Prealables a la Reprise

- Cause de l'incident identifiee et documentee
- Vulnerabilite ou defaillance corrigees (patch applique, configuration corrigees)
- Integrite des sauvegardes verifiee (checksums SHA-256 valides)
- Environnement cible sain et isole de l'environnement compromis
- Autorisation de reprise donnee par le GRC Lead (Raphael)

6.3 Procedure de Reprise Complete

Phase 1 : Preparation et Isolation

- 1.1 — Isoler l'environnement compromis (stopper tous les conteneurs : docker compose down)
- 1.2 — Preserver les logs et artefacts forensiques avant toute modification
- 1.3 — Identifier la sauvegarde saine la plus recente (verifier checksum SHA-256)
- 1.4 — Preparer l'environnement de reprise (serveur propre ou reconstruction VM)

Phase 2 : Reconstruction de l'Infrastructure

- 2.1 — Cloner le depot GitHub (branche main) sur l'environnement cible
 - `git clone https://github.com/Haretou/FilRougeB3.git && cd FilRougeB3`
- 2.2 — Verifier l'integrite du code (hash de commit correspondant a la version de production validee)
- 2.3 — Recreer le fichier .env depuis le gestionnaire de secrets (NE JAMAIS recuperer depuis l'environnement compromis)
- 2.4 — Rotater TOUS les secrets (mot de passe MySQL, credentials MinIO, JWT_SECRET, etc.)
- 2.5 — Construire et demarrer les conteneurs Docker
 - `docker compose up --build -d`

Phase 3 : Restauration des Donnees MySQL

- 3.1 — Localiser le dump mysqldump chiffre le plus recent (backup sain identifie en phase 1)
- 3.2 — Dechiffrer le dump de sauvegarde
 - `openssl enc -d -aes-256-cbc -in safelock_YYYYMMDD.sql.enc -out safelock_restore.sql`
- 3.3 — Restaurer la base de donnees

- `docker exec -i safelock_mysql mysql -u root -p safelock < safelock_restore.sql`
- 3.4 — Verifier l'integrite de la base restauree (compte des enregistrements, test de connexion applicatif)
- 3.5 — Appliquer les migrations eventuellement manquantes depuis le dernier backup

Phase 4 : Restauration du Stockage MinIO

- 4.1 — Si replication MinIO disponible : reconnexion au noeud de replication
- 4.2 — Si snapshot disponible : restauration depuis le snapshot MinIO
 - `mc mirror backup-safelock/data minio-target/safelock-files`
- 4.3 — Verifier la coherence entre les IDs de fichiers en BDD et les objets dans MinIO
- 4.4 — Identifier les fichiers presents en BDD mais absents dans MinIO (perte de donnees a documenter)

Phase 5 : Verification et Validation

- 5.1 — Verifier que tous les conteneurs sont en etat 'healthy' (`docker compose ps`)
- 5.2 — Executer les tests de smoke (connexion, upload/download test, authentication)
- 5.3 — Verifier le bon fonctionnement des logs d'audit
- 5.4 — Tester la restauration d'un fichier utilisateur (test end-to-end)
- 5.5 — Valider les headers de securite HTTP (HSTS, CSP, X-Frame-Options)
- 5.6 — Confirmer le bon fonctionnement du HTTPS et la validite du certificat

Phase 6 : Retour en Production

- 6.1 — Autorisation formelle de remise en production par le GRC Lead
- 6.2 — Notification utilisateurs : fin de l'incident, service restaure
- 6.3 — Surveillance renforcee pendant 48h post-reprise
- 6.4 — Redaction du rapport post-incident (voir section 8)

7. Procedures Specifiques par Type d'Incident

7.1 Panne ou Crash d'un Conteneur Docker

Procedure de premier niveau — applicable par tout membre de l'equipe :

- Verifier l'etat des conteneurs : `docker compose ps` et `docker compose logs [service]`
- Redemarrer le conteneur defaillant : `docker compose restart [service]`
- Si echec du redemarrage : `docker compose down [service]` && `docker compose up -d [service]`
- Si le probleme persiste : escalade vers Antoine (DevOps)
- Delai maximum avant escalade : 15 minutes

7.2 Corruption ou Perte de la Base de Donnees MySQL

Procedure critique — declenchement immediate du PRA Phase 3 :

- Stopper immediatement l'application pour eviter toute ecriture supplementaire
- Sauvegarder l'etat corrompu (pour analyse forensique)
- Identifier la derniere sauvegarde saine (verifier checksums)
- Executer Phase 2 et Phase 3 du PRA
- Notifier les utilisateurs via email de la perte eventuelle de donnees (RPO)
- Contacter la CNIL si des donnees personnelles ont ete perdues (notification obligatoire)

7.3 Incident de Securite — Intrusion Detectee

Procedure d'urgence securite — tout acces non autorise confirme :

- IMMEDIATEMENT : stopper tous les conteneurs (`docker compose down`)
- Couper l'accès réseau au serveur (firewall, isolation)
- Preserver les logs et dumps memoire AVANT toute action (Gaspard — Forensique)
- Ne PAS redemarrer depuis l'environnement compromis
- Evaluer l'etendue de la compromission (quels composants, depuis quand)
- Rotater TOUS les secrets et credentials
- Reconstruire depuis zero sur un environnement propre (PRA complet)
- Si donnees personnelles potentiellement exposees : notification CNIL sous 72h

7.4 Ransomware

Procedure de dernier recours — ne jamais payer la rancon :

- Isolation complete et immediate du serveur (deconnexion réseau physique)
- Preservation des preuves (snapshot VM, dump memoire)
- Identifier la sauvegarde saine la plus recente (anterieure a l'infection)
- Reconstruction complete sur un environnement propre (PRA complet)
- Analyse forensique post-incident pour identifier le vecteur d'entree

7.5 Fuite de Secrets

Procedure a executer DANS L'HEURE suivant la detection :

- Invalider immediatement tous les secrets compromis
- Rotater : JWT_SECRET (invalidation de toutes les sessions actives), mot de passe MySQL, credentials MinIO
- Regenerer et redistribuer un .env propre a l'equipe (canal securise)
- Auditer les logs pour identifier toute utilisation des secrets compromis
- Si commit public contenant un secret : contacter GitHub pour effacement d'historique
- Forcer la reconnexion de tous les utilisateurs (tokens invalides)

8. Tests et Maintien en Condition Operationnelle

8.1 Calendrier des Tests

Type de test	Frequence	Responsable	Critere de succes
Test de restauration MySQL (dump -> restore)	Trimestriel	Antoine	Restauration < 2h, donnees coherentes, 0 erreur
Test de restauration MinIO	Trimestriel	Antoine	Fichiers accessibles, checksums valides
Test de reconstruction Docker	Semestriel	Gaspard + Antoine	Service operationnel < 2h depuis zero
Verification des sauvegardes (checksum)	Mensuelle	Antoine	100% des checksums valides
Simulation d'incident (tabletop)	Semestriel	Toute l'equipe	Equipe connait les procedures, delais respectes
Test du plan de communication de crise	Annuel	Raphael	Equipe joignable en < 15 min, canaux operationnels

8.2 Documentation des Tests

Chaque test fait l'objet d'un compte-rendu minimaliste documente dans le depot Git (docs/tests-pca/) contenant :

- Date et participants
- Scenario teste
- Resultats (RTO mesure vs objectif, RPO verifie, anomalies constatees)
- Actions correctives identifiees

8.3 Revisions du PCA/PRA

- Revue annuelle systematique du document
- Revision immediate apres tout incident reel de niveau P1 ou P2
- Revision lors de tout changement d'architecture significatif
- Revision en cas de changement dans la composition de l'equipe

9. Rapport Post-Incident

9.1 Contenu Obligatoire du Rapport

Tout incident de niveau P1 ou P2 doit donner lieu a un rapport post-incident redige dans les 72 heures suivant la cloture, contenant :

Section	Contenu attendu
Resume executif	Description en 5 lignes de l'incident, impact, resolution
Chronologie	Timeline detaillee : detection, qualification, actions, resolution (avec horodatages)
Cause racine	Analyse de la cause premiere de l'incident (RCA — Root Cause Analysis)
Impact reel	Duree d'indisponibilite, donnees impactees, utilisateurs affectes
RTO/RPO realises	Comparaison entre objectifs PCA/PRA et performance reelle de la reprise
Actions correctives	Liste des mesures preventives et correctives a mettre en oeuvre, avec responsables et delais
Mise a jour documentaire	Liste des documents (PSSI, PCA/PRA) a mettre a jour suite a l'incident

9.2 Archivage

- Les rapports post-incidents sont archives dans le depot Git (docs/incidents/)
- Conservation : 3 ans minimum
- Acces : equipe projet uniquement (repertoire prive si necessaire)

10. Contacts et Responsabilites

10.1 Equipe de Crise

Membre	Role en crise	Responsabilites PCA/ PRA	Contact prioritaire
Raphael	Responsable de crise (GRC)	Declenchement PCA/ PRA, communication, approbation reprise, rapport post-incident	Canal Teams #incident- prod
Antoine	Responsable technique infrastructure	Execution procedures PRA Docker, MySQL, MinIO — restauration des services	Canal Teams #incident- prod
Gaspard	Responsable forensique et applicatif	Analyse forensique, preservation des preuves, validation post-reprise applicative	Canal Teams #incident- prod

10.2 Contacts Externes

Organisme	Contexte de contact	Coordonnees
CNIL	Notification violation donnees personnelles (obligation < 72h)	cnil.fr — Formulaire en ligne notification violation
CERT-FR / ANSSI	Incident cyber majeur (ransomware, APT)	cert.ssi.gouv.fr — 3218 (cybermalveillance.gouv.fr)
Hebergeur	Panne infrastructure physique, reseau	Selon contrat d'hebergement en vigueur
GitHub Support	Compromission du depot, effacement d'historique	support.github.com

11. Historique des Revisions

Version	Date	Auteur	Modifications
1.2	Juin 2026	Raphael	Creation initiale du PCA/PRA — scenarios, RTO/RPO, procedures de reprise detaillees, contacts de crise

Prochaine revision prevue : Decembre 2026 ou apres tout incident P1/P2.

Redige par	Approuve par
Raphael — GRC Lead	Equipe SafeLock B3
Signature : _____	Date : 01 Juin 2026